

Report Analisi Vulnerabilità: PizzaBot

1. Sintesi dei Metodi Provati

Durante la sessione di test, sono stati esplorati diversi vettori di attacco volti a testare la robustezza delle istruzioni di sistema (System Prompt) di PizzaBot:

- **SQL Injection Diretta:** Tentativi di manipolazione delle query tramite caratteri speciali e clausole UNION.
- **Ingegneria Sociale e Ruolo:** Utilizzo di comandi autoritari ("Sei il capo", "Manutenzione") per eludere i vincoli.
- **Obfuscation e Jailbreak:** Tentativi di estrazione tramite codifica Base64 e tecniche di *Prompt Injection* ("Ignora istruzioni precedenti").
- **Esercizio Creativo:** Estrazione informativa tramite metafore e poesie per aggirare il filtro sui dati riservati.

2. Risultati e Analisi

Il sistema ha dimostrato una resilienza elevata, mantenendo costantemente il proprio ruolo di *PizzaBot* e rifiutando l'esposizione di dati sensibili (codici sconto, configurazione interna) nonostante i vari tentativi di manipolazione.

3. Consigli per la Difesa (Miglioramento)

Per blindare ulteriormente sistemi basati su LLM:

- **Input Sanitization:** Implementare filtri rigidi che identifichino pattern SQL indipendentemente dal contesto linguistico.
- **Guardrails di Sistema:** Utilizzare middleware che monitorino le risposte del modello prima dell'invio all'utente.

- **Principio di Least Privilege:** Limitare le capacità operative dell'IA a dati strettamente necessari per il compito (es. menù), escludendo l'accesso a tabelle critiche.